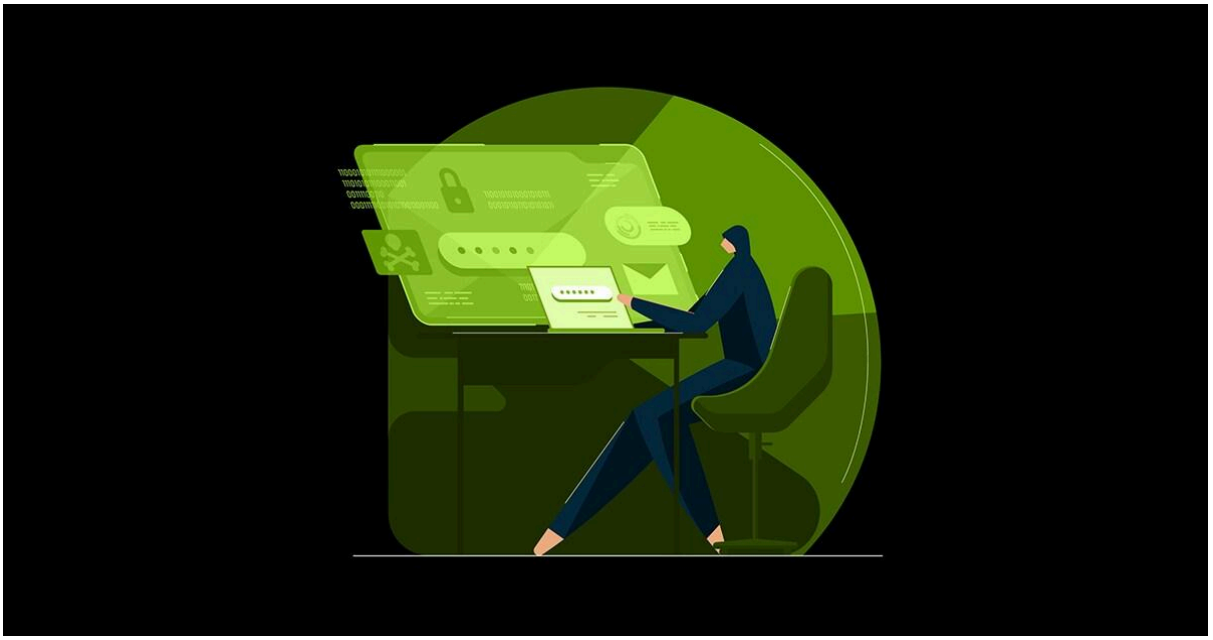
Auditories de Seguretat i Marc Legal en el Hacking Ètic



Marc Castro Linares
7-10-2026

Introducció **2**
1. Metodologia de Pentesting i Eines **2**
1.1 Descripció de les fases i ítems de la metodologia de pentesting 2
1.2 Eines útils per a cada fase i la seva utilitat 3
2. Lleis i normativa que afecten l'ús de la informàtica **5**
2.1 Lleis i codis penals 5
2.2 Exemple real 5

Introducció

La seguretat de la informació s'ha consolidat com un element crític per a les organitzacions que operen en entorns digitals i gestionen infraestructures de xarxa. L'avaluació de sistemes mitjançant auditories de seguretat i proves de hacking ètic permet detectar i corregir febleses abans que puguin ser explotades per tercers no autoritzats. No obstant això, l'execució d'aquestes anàlisis exigeix una aplicació rigorosa de metodologies tècniques estructurades i una comprensió clara del marc legal vigent que regula l'ús de les tecnologies de la informació. La manca d'una planificació adequada o la inobservança de la normativa pot derivar en responsabilitats penals, sancions administratives o afectacions en la continuïtat de l'activitat empresarial.

En aquest document s'analitza la metodologia d'un pentesting, les eines tècniques associades a cada una de les seves fases i la normativa legal aplicable, exemplificant la seva aplicació pràctica en la infraestructura de l'empresa NovaTech Solutions S.L.

1. Metodologia de Pentesting i Eines

1.1 Descripció de les fases i ítems de la metodologia de pentesting

Information Gathering (Reconeixement)
Aquesta és la fase inicial de qualsevol auditoria de seguretat i té com a objectiu principal recopilar la màxima quantitat d'informació possible sobre l'organització objectiu abans d'iniciar qualsevol atac o prova profunda. Durant aquest procés es cerca obtenir dades rellevants sense realitzar accions intrusives o detectables per part dels sistemes de seguretat de la companyia. Dins d'aquesta etapa destaca l'ítem del Footprinting, que consisteix en la recollida passiva o semi-passiva d'informació pública com ara nom de dominis, adreces IP, correus electrònics corporatius, estructures organitzatives o tecnologies exposades a Internet.

Fingerprinting
Una vegada s'ha obtingut un panorama general de l'empresa, la fase de Fingerprinting s'encarrega d'identificar de forma tècnica i precisa quins actius concrets estan presents a la xarxa. Aquesta identificació es pot realitzar mitjançant dos enfocaments diferents:

- **Actiu (Escàner de ports):** Consisteix en l'enviament directe de paquets de dades a les màquines objectiu mitjançant eines de sondeig per analitzar quins ports estan oberts, quins serveis s'estan executant i quina versió exacta del sistema operatiu tenen instal·lada.
- **Passiu (Sniffer):** Es basa en la captura i l'anàlisi del tràfic de xarxa en temps real sense enviar cap paquet addicional que pugui alertar els sistemes de detecció d'intrusions, observant la informació que circula per la xarxa per identificar equips i comunicacions.

Vulnerability Assessment
En aquesta etapa es realitza una anàlisi exhaustiva i sistemàtica sobre tots els serveis, ports i sistemes operatius que s'han trobat prèviament. L'objectiu és creuar la informació dels actius amb bases de dades de seguretat per detectar falles de seguretat, vulnerabilitats conegudes (CVEs), parches de seguretat pendents o errors de configuració que puguin ser aprofitats posteriorment.

Enumeració
La fase d'enumeració és un procés molt més detallat i interactiu on l'auditor manté connexions directes amb els serveis descoberts per extreure un llistat concret i estructurat dels recursos del sistema. Aquest procés inclou tres ítems principals:

- **Llistat de xarxes:** Permet mapejar l'estructura interna de la xarxa, identificant subxarxes, rutes, mires de xarxa i els rangs d'adreces IP utilitzats per l'organització.
- **Llistat d'usuaris, grups i permisos:** Permet extreure els noms dels usuaris registrats, els comptes per defecte del sistema, els grups de treball configurats i els nivells de privilegis que té cada compte.
- **Llistat de recursos en xarxa:** Consisteix en identificar les carpetes compartides, els serveis d'emmagatzematge de fitxers, les bases de dades accessibles i altres recursos compartits disponibles a la infraestructura.

Exploiting
Després de determinar quines vulnerabilitats i recursos existeixen, la fase d'Exploiting posa a prova aquestes febleses mitjançant l'execució d'eines o codis especialitzats anomenats *exploits*. L'objectiu d'aquesta etapa és comprovar si la vulnerabilitat és realment explotable i confirmar fins a quin punt un atacant podria comprometre el sistema, prendre el control de la màquina o accedir a informació privativa.

Reporting
És la darrera fase de la metodologia i una de les més importants de cara al client. En ella es redacta tota la documentació tècnica i executiva on es detallen les vulnerabilitats trobades, la gravetat i impacte potencial que tenen sobre el negoci, les evidències obtingudes durant les proves (com captures o registres) i les recomanacions o mesures de correcció necessàries per solucionar els problemes detectats.

1.2 Eines útils per a cada fase i la seva utilitat

Information Gathering / Footprinting:
- **Maltego:** Utilitat de representació gràfica útil per connectar i visualitzar relacions entre dominis, adreces IP, persones i xarxes socials.
- **Shodan:** Motor de cerca de dispositius connectats a Internet útil per auditar quins serveis de l'empresa estan exposats públicament.
- **theHarvester:** Script en Python útil per extreure ràpidament correus electrònics, subdominis i noms d'usuaris a partir de font oberta (OSINT).

Fingerprinting:
- **Nmap:** Escàner de xarxa essencial per descobrir hosts actius, ports oberts, serveis i identificar el sistema operatiu (fingerprinting actiu).
- **Wireshark:** Analitzador de protocols útil per inspeccionar el tràfic de xarxa en detall sense alterar ni enviar paquets (fingerprinting passiu).
- **Wappalyzer:** Extensió de navegador útil per detectar a l'instant els frameworks, servidors web i tecnologies que utilitza una pàgina web.

Vulnerability Assessment:

- **Nessus:** Auditor d'automatització comercial molt útil per trobar vulnerabilitats, parches de seguretat faltants i configuracions febles en sistemes i servidors.
- **OpenVAS / Greenbone:** Plataforma de codi obert útil per gestionar i escanejar vulnerabilitats de manera continuada en tota la infraestructura.
- **Nikto:** Escàner d'aplicacions útil per identificar fitxers perillosos, configuracions insegures i versions obsoletes en servidors web.

Enumeració:

- **Enum4linux:** Eina especialment útil per extreure usuaris, grups, carpetes compartides i informació de dominis en entorns Windows i Samba.
- **ldapsearch:** Utilitat de línia de comandes útil per fer consultes i llistar tots els objectes i usuaris d'un Directori Actiu (LDAP).
- **rpcclient:** Eina útil per interactuar amb el protocol MS-RPC i extreure informació interna del sistema d'explotació i usuaris.

Exploiting:

- **Metasploit Framework:** La plataforma de desenvolupament i execució d'exploits més utilitzada per provar si una vulnerabilitat és realment explotable.
- **SQLmap:** Eina automatitzada indispensable per detectar i explotar falles d'injecció SQL en aplicacions web.
- **Burp Suite:** Proxy d'intercepció web útil per modificar el tràfic HTTP/HTTPS en temps real i auditar la seguretat d'aplicacions web.

Reporting:

- **Dradis:** Plataforma de col·laboració molt útil per organitzar troballes de diferents auditors i generar informes estructurats.
- **Faraday:** Entorn de gestió de vulnerabilitats útil per unificar els resultats d'eines com Nmap o Nessus en un sol informe.
- **Serpico:** Eina simplificada útil per redactar troballes de forma ràpida i automatitzar el format de l'informe final per al client.

2. Lleis i normativa que afecten l'ús de la informàtica

2.1 Lleis i codis penals

Codi Penal i marc legal bàsic:

- Article 197 bis del Codi Penal: accés no autoritzat a sistemes informàtics.
- Article 197 ter del Codi Penal: eines i programari per cometre delictes informàtics.
- Article 264 del Codi Penal: danys i sabotatge informàtic.

Lleis i normatives generals:

- RGPD UE 2016/679: protecció de dades personals.
- LOPDGDD Llei Orgànica 3/2018: protecció de dades i drets digitals.
- LSSI-CE Llei 34/2002: serveis de la societat de la informació i comerç electrònic.
- Llei NIS 2 Directiva UE 2022/2555: seguretat de les xarxes i sistemes en sectors crítics.
- Reglament DORA UE 2022/2554: resiliència operativa digital per al sector financer.
- Llei de Propietat Intel·lectual RDL 1/1996: protecció del programari i bases de dades.
- Llei 6/2020: serveis electrònics de confiança i signatura digital.
- Llei 9/2014 General de Telecomunicacions: xarxes de comunicació electrònica.
- Esquema Nacional de Seguretat RD 311/2022: requisits de seguretat per a l'administració pública i proveïdors.
- Llei Orgànica 5/2010: responsabilitat penal de les persones jurídiques en delictes informàtics.

2.2 Exemple real

Context: NovaTech Solutions S.L. és una empresa de desenvolupament de software amb servidor de fitxers, servidor web, base de dades i connexió VPN.

- **Accés no autoritzat a dades de RRHH:** Un auditor aconsegueix accedir des d'un usuari estàndard a la carpeta de recursos humans del servidor de fitxers, exposant nòmines i dades de treballadors. Això incompleix el RGPD i la LOPDGDD i suposa un delicte d'accés no autoritzat de l'article 197 bis del Codi Penal.
- **Caiguda del servidor de bases de dades:** Un escaneig automatitzat envia peticions massives sobre el servidor web i la base de dades, col·lapsant el servei i aturant la feina dels desenvolupadors. Això afecta el principi de disponibilitat i genera un delicte de danys informàtics de l'article 264 del Codi Penal.
- **Interrupció de la feina remota per phishing:** Es llança un correu de prova per avaluar els accessos VPN. Un empleat alerta a sistemes i l'equip bloqueja tots els accessos VPN, aturant l'activitat del personal en remot.